

SQL Injection using Burp Suite in OWASP Juice Shop

AIM: To perform SQL Injection attack using **Burp Suite** on Juice Shop.

REQUIREMENTS

- Kali Linux
- Burp Suite
- Web browser
- Juice Shop (local or online)

STEP-BY-STEP PROCESS

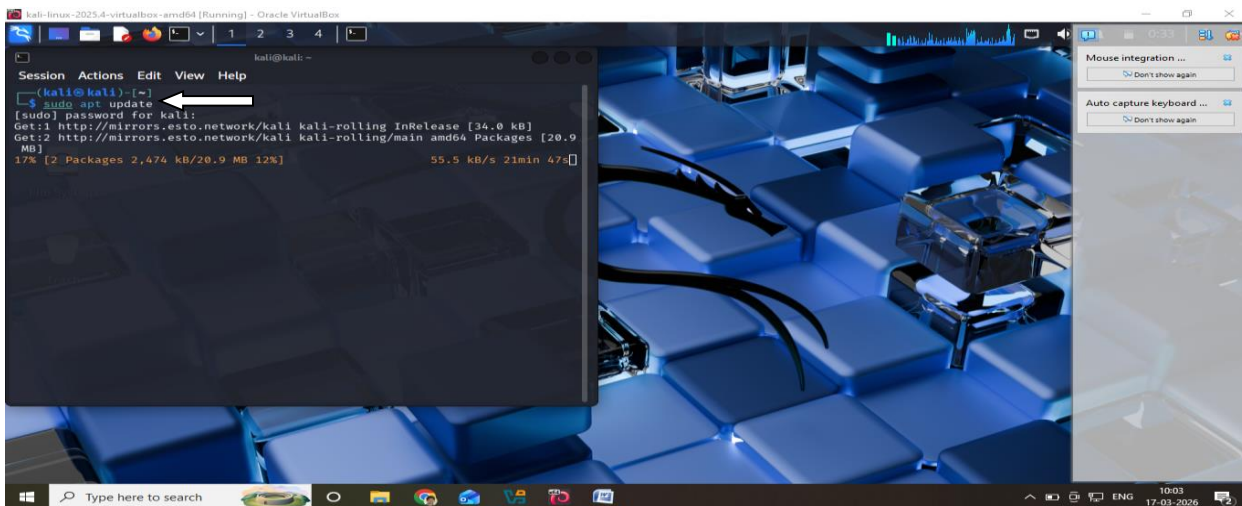
1. Start Juice Shop in Kali Linux

Juice Shop can run with Docker or Node.js. Docker is easiest.

Step 1: Install Docker (if not installed)

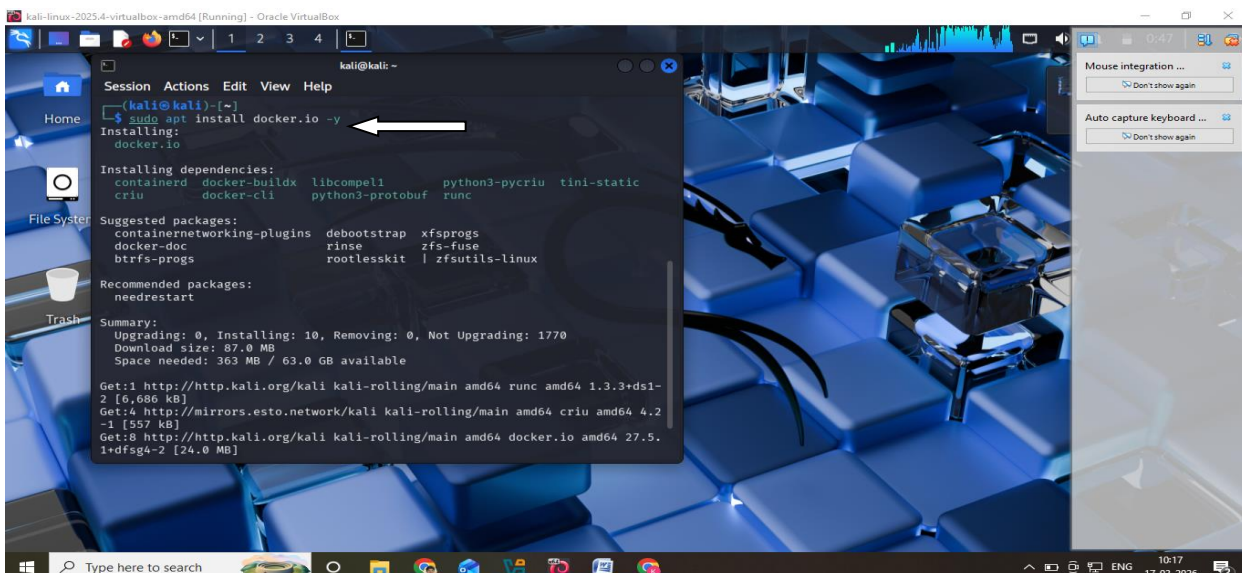
Open terminal in Kali:

sudo apt update



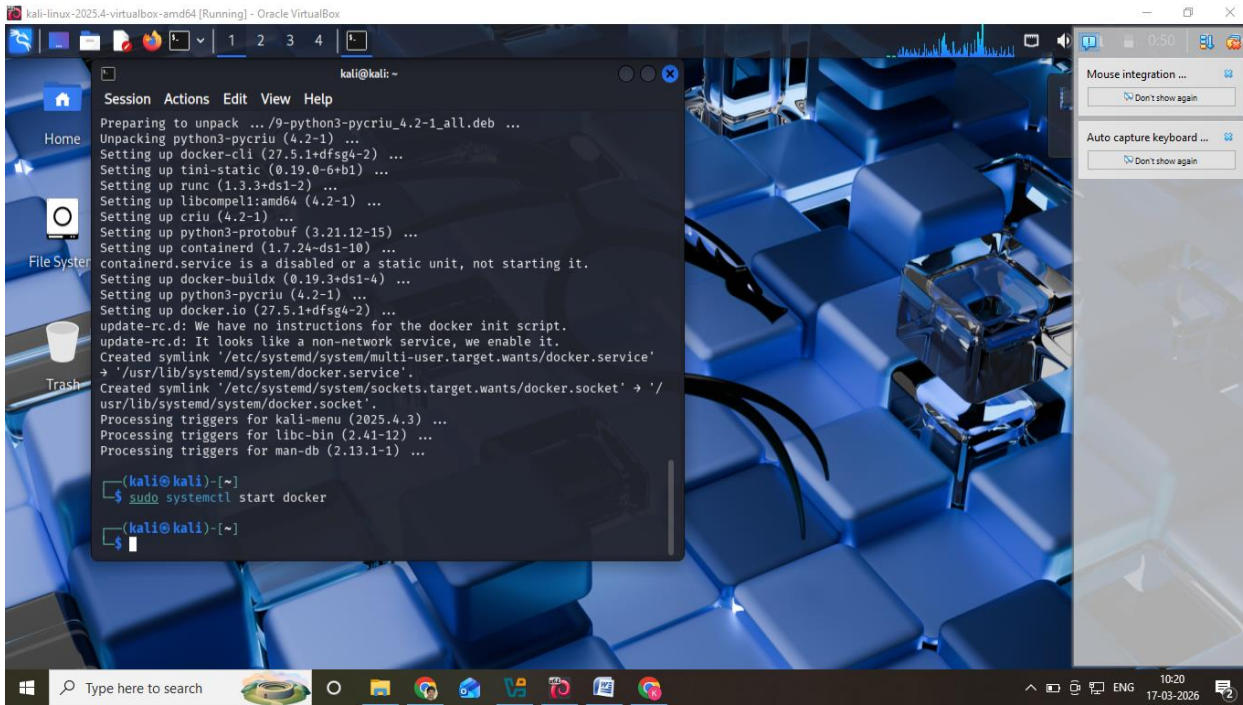
```
kali@kali: ~  
$ sudo apt update  
[sudo] password for kali:  
Get:1 http://mirrors.esto.network/kali kali-rolling InRelease [34.0 kB]  
Get:2 http://mirrors.esto.network/kali kali-rolling/main amd64 Packages [20.9 MB]  
17% [2 Packages 2,474 kB/20.9 MB 12%] 55.5 kB/s 21min 47s
```

sudo apt install docker.io -y

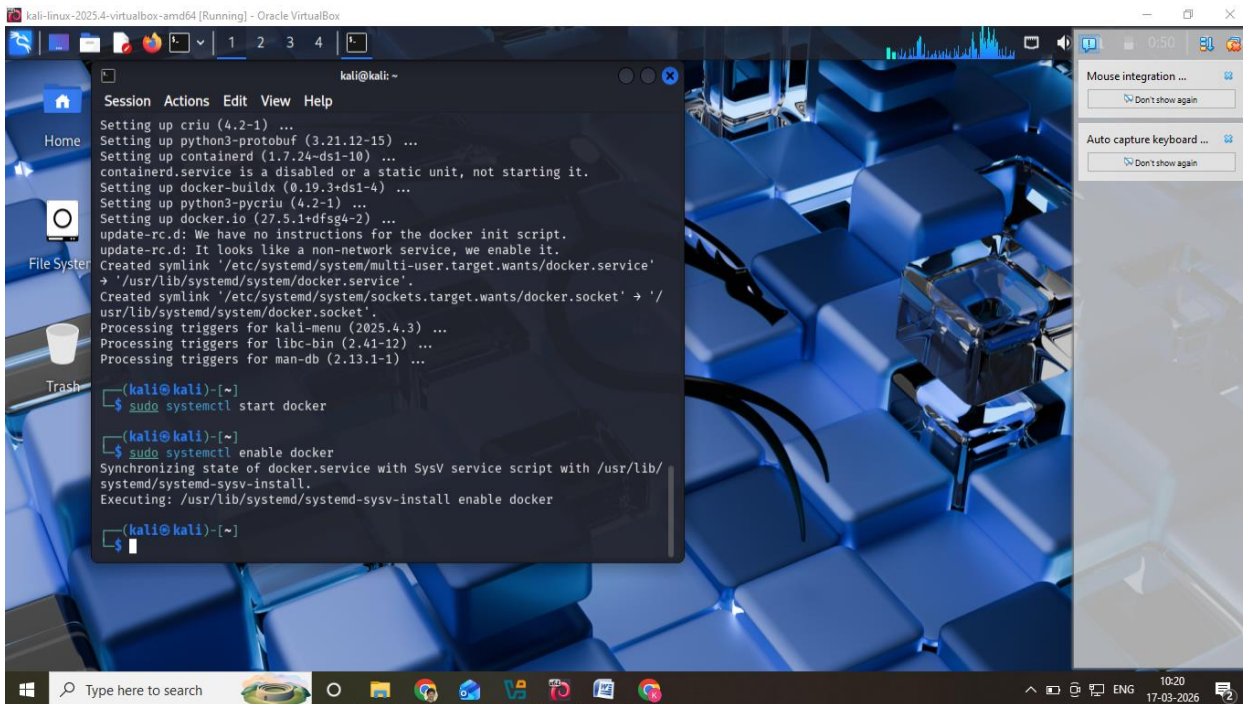


```
kali@kali: ~  
$ sudo apt install docker.io -y  
Installing:  
docker.io  
  
Installing dependencies:  
containerd docker-buildx libcompel1 python3-pycrui tini-static  
criu docker-cli python3-protobuf runc  
  
Suggested packages:  
containernetworking-plugins debootstrap xfsprogs  
docker-doc rinse zfs-fuse  
btrfs-progs rootlesskit | zfsutils-linux  
  
Recommended packages:  
needrestart  
  
Summary:  
Upgrading: 0, Installing: 10, Removing: 0, Not Upgrading: 1770  
Download size: 87.0 MB  
Space needed: 363 MB / 63.0 GB available  
  
Get:1 http://http.kali.org/kali kali-rolling/main amd64 runc amd64 1.3.3+ds1-2 [5,686 kB]  
Get:4 http://mirrors.esto.network/kali kali-rolling/main amd64 criu amd64 4.2-1 [557 kB]  
Get:8 http://http.kali.org/kali kali-rolling/main amd64 docker.io amd64 27.5.1+dfsg4-2 [24.0 MB]
```

sudo systemctl start docker

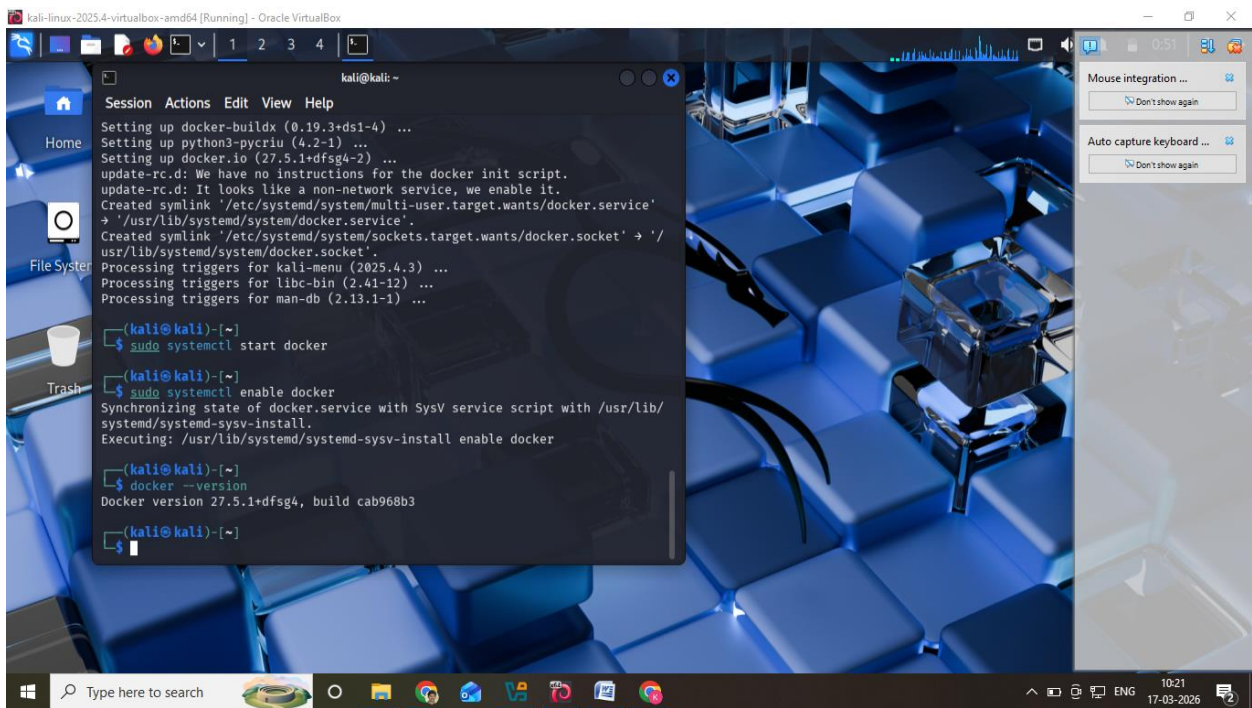


sudo systemctl enable docker



Verify:

`docker --version`



Run:

```
sudo usermod -aG docker $USER
```

Restart the session (important):

```
reboot
```

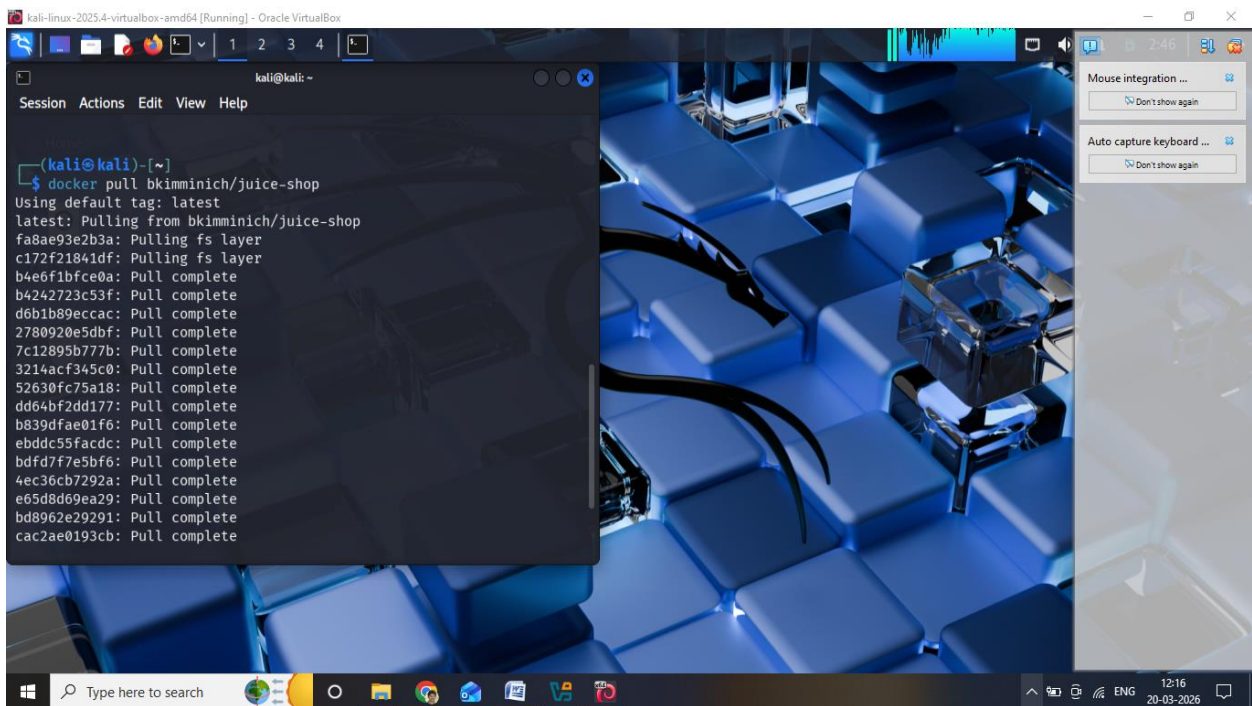
OR logout and login again.

Test Docker:

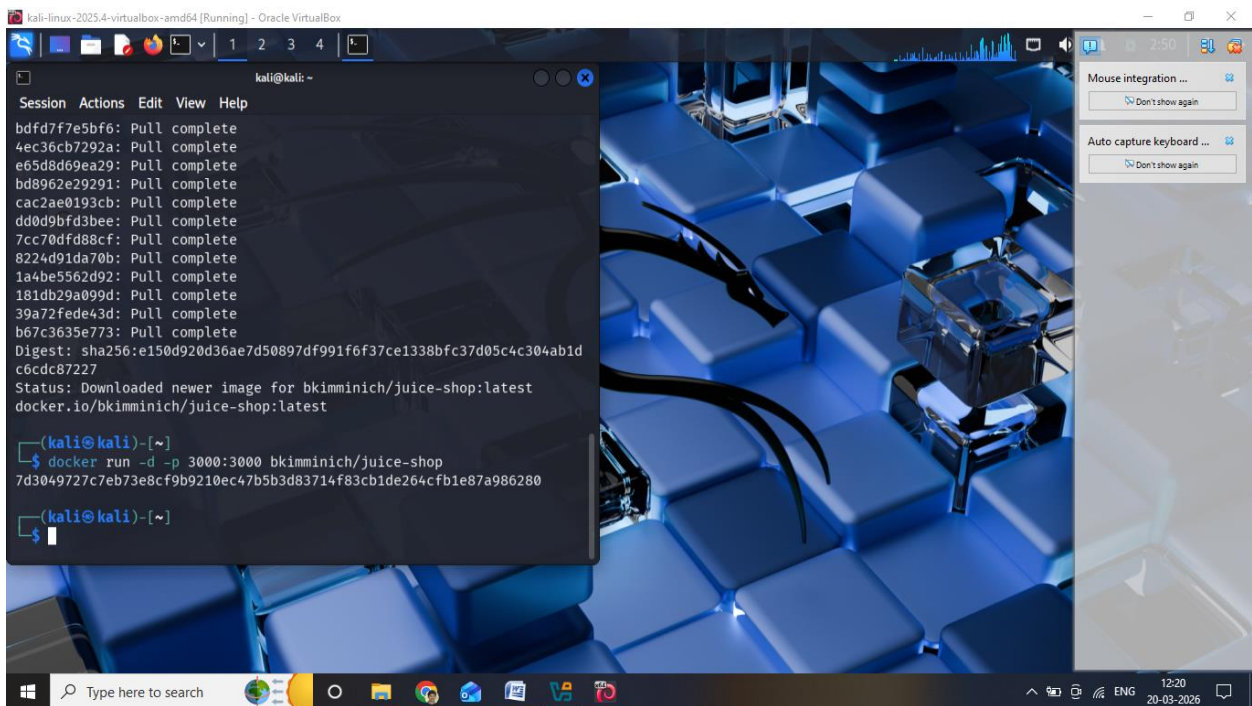
```
docker run hello-world
```

Download and Run Juice Shop

```
docker pull bkimminich/juice-shop
```

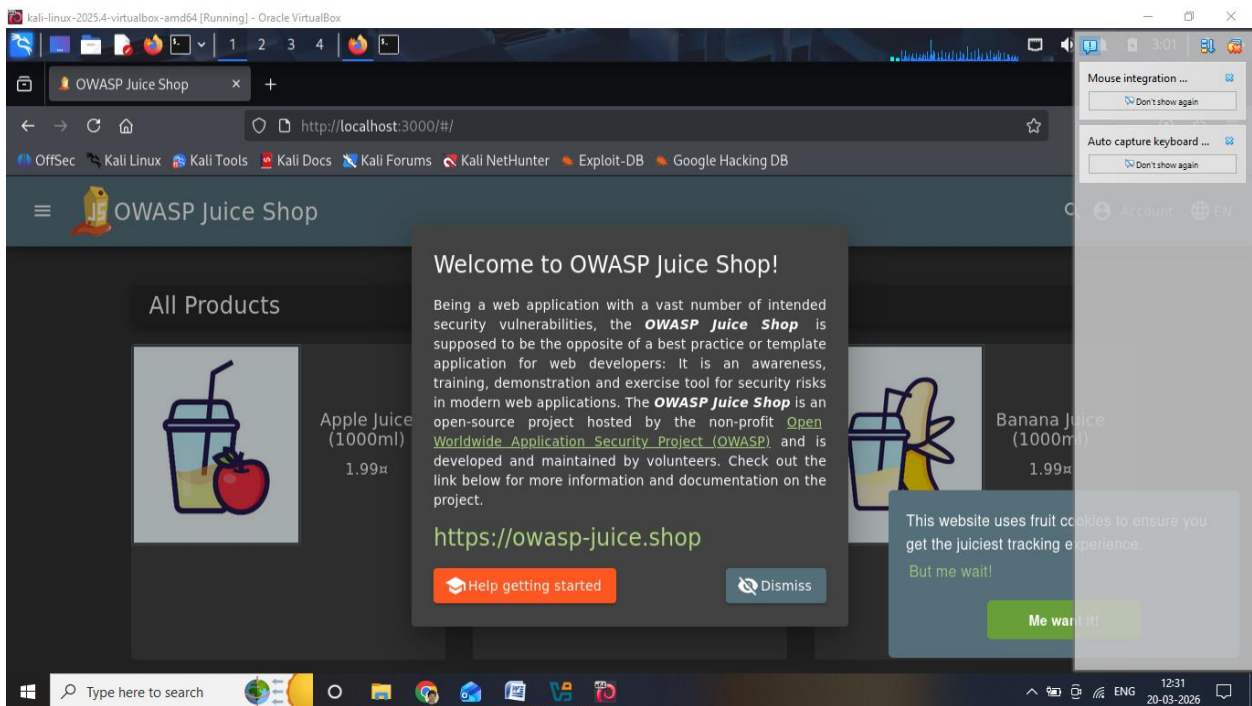
docker run -d -p 3000:3000 bkimminich/juice-shop



Step 3: Open the Application

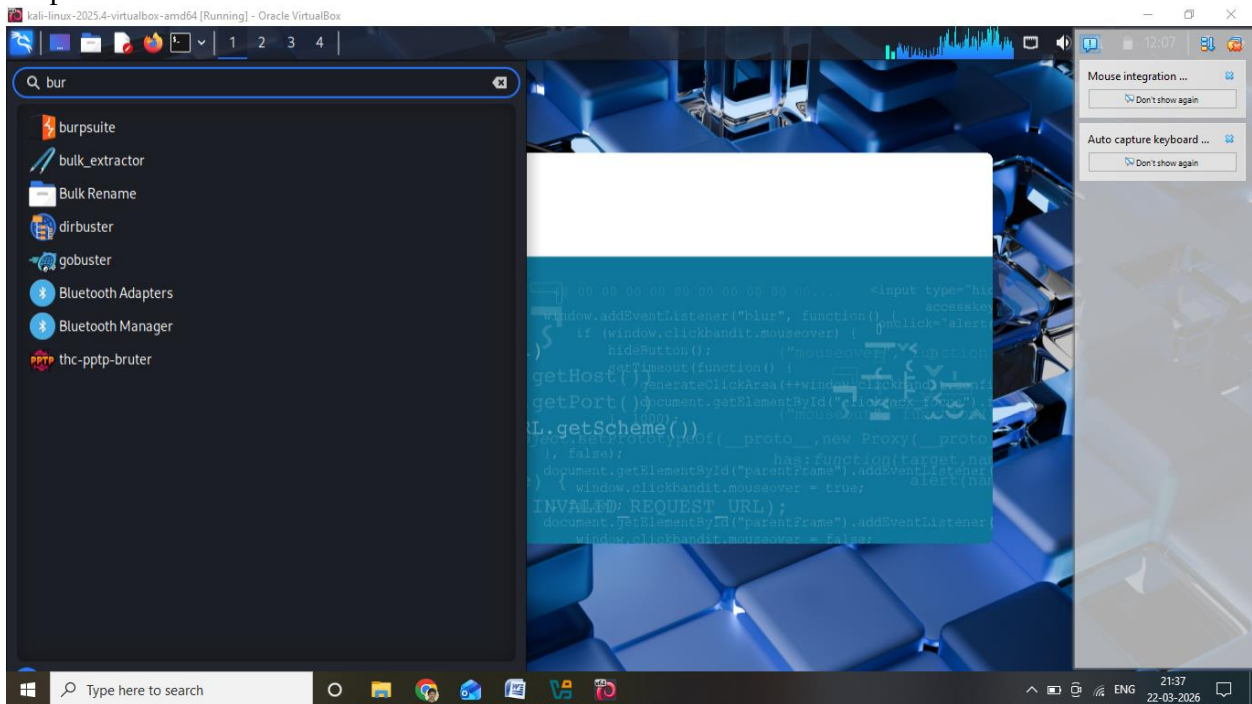
Open browser in Kali and go to:

<http://localhost:3000>

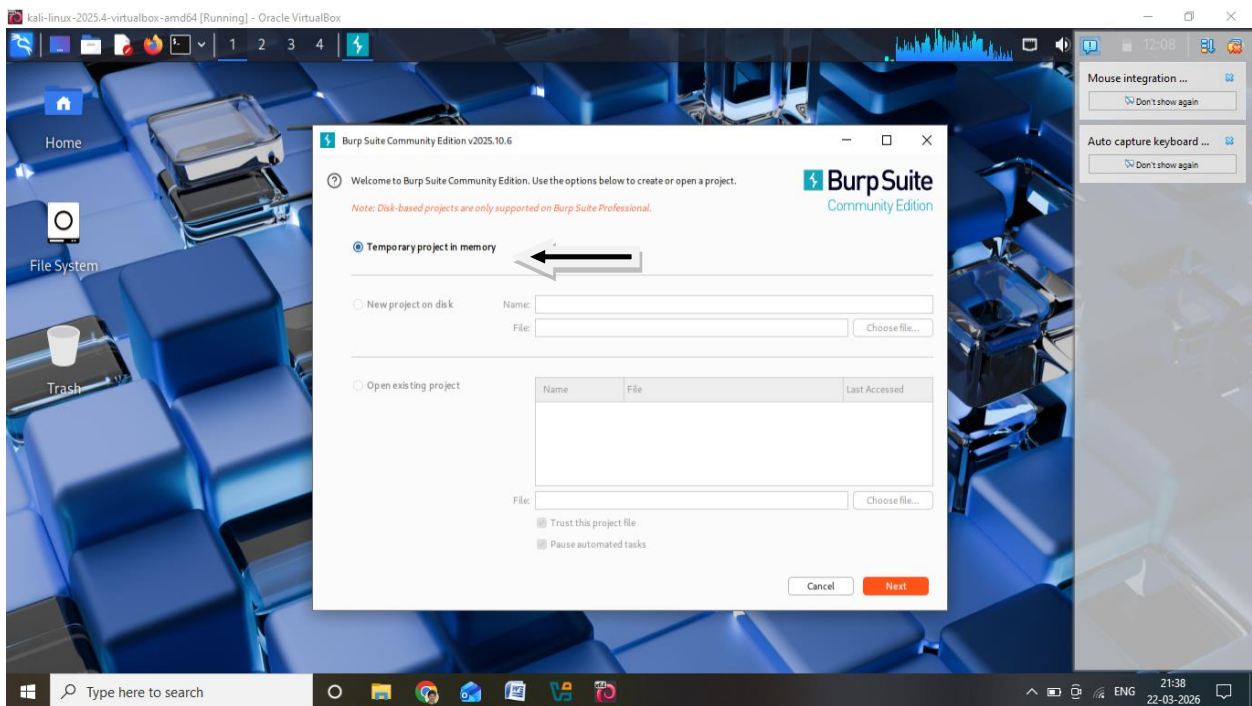


STEP 1: Open Burp Suite

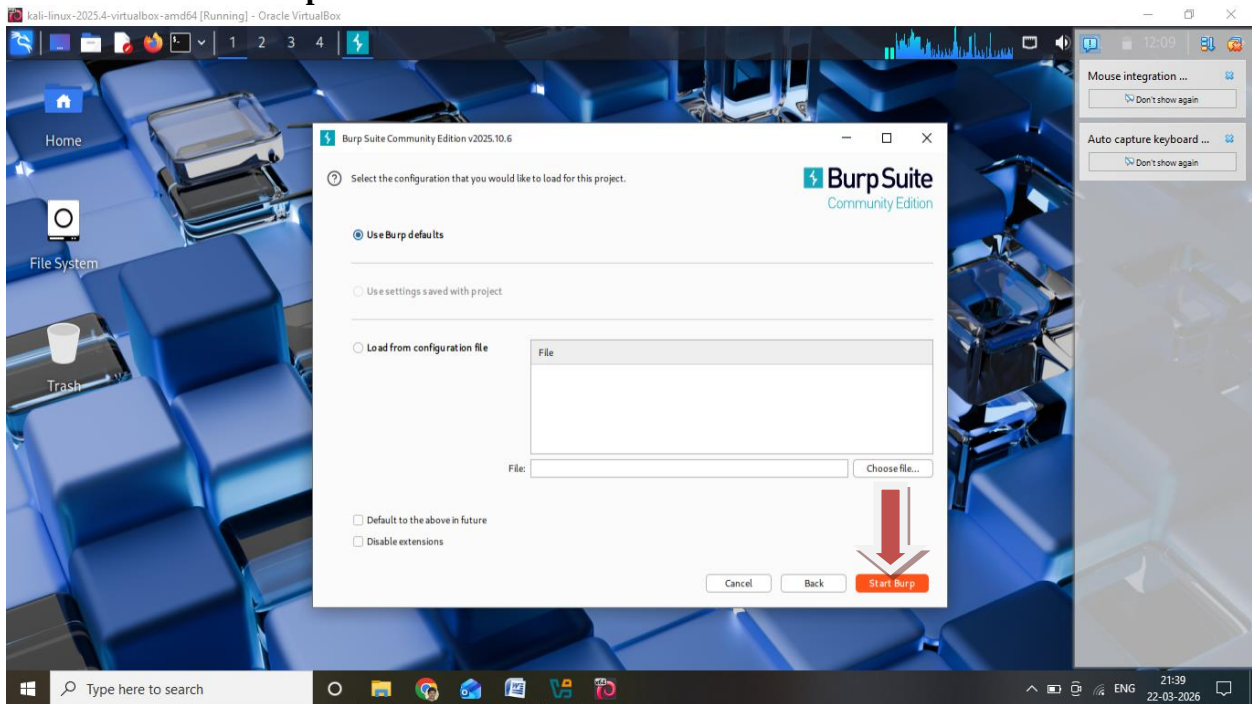
Open terminal:
Burpsuite



- Select Temporary Project



• Click Start Burp

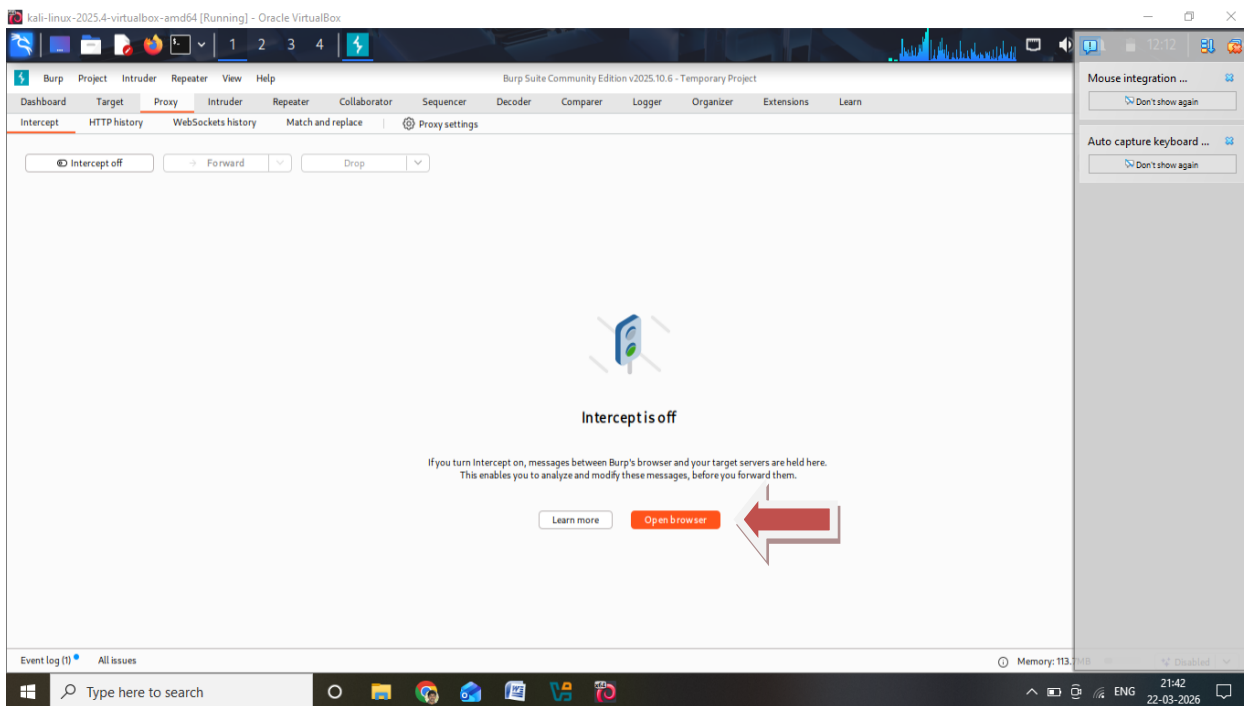


STEP 2: Open Burp Browser

In Burp:

Go to **Proxy** tab

Click “Open Browser”



This browser is already configured with proxy (no manual setup needed)

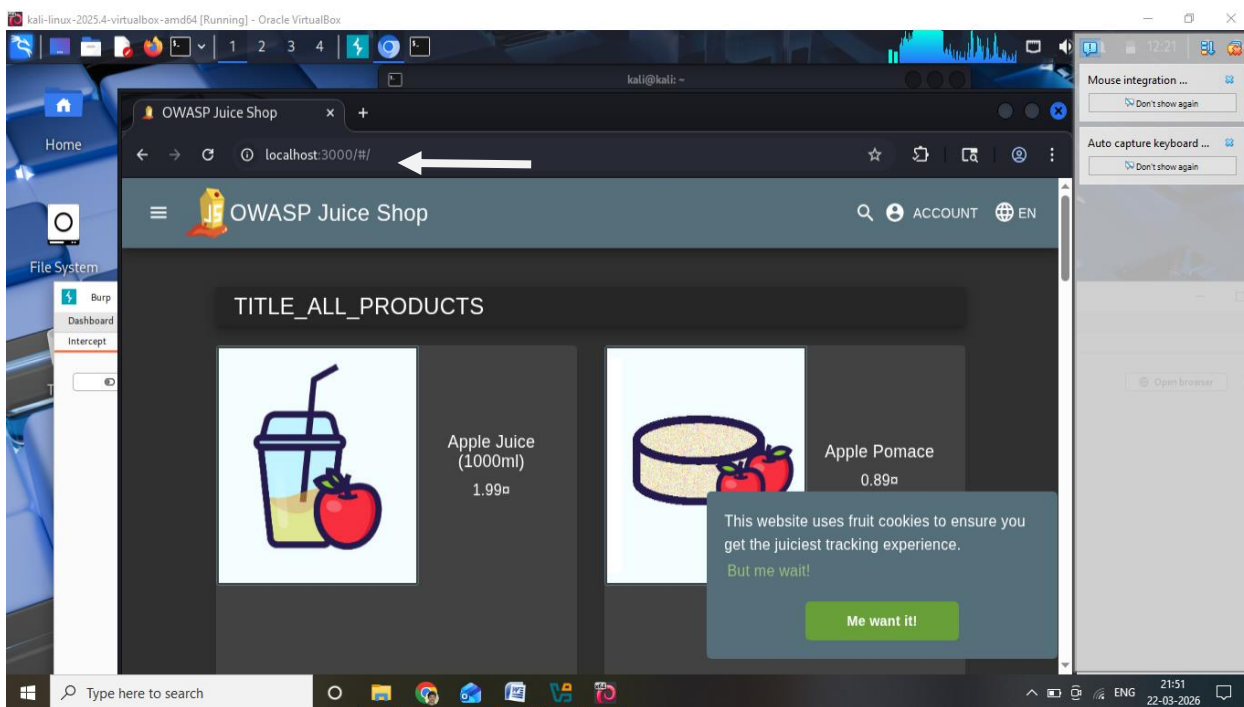
STEP 3: Open Juice Shop Website

In Burp browser, open:

<https://juice-shop.herokuapp.com/#/login>

OR (local):

<http://localhost:3000/#/login>



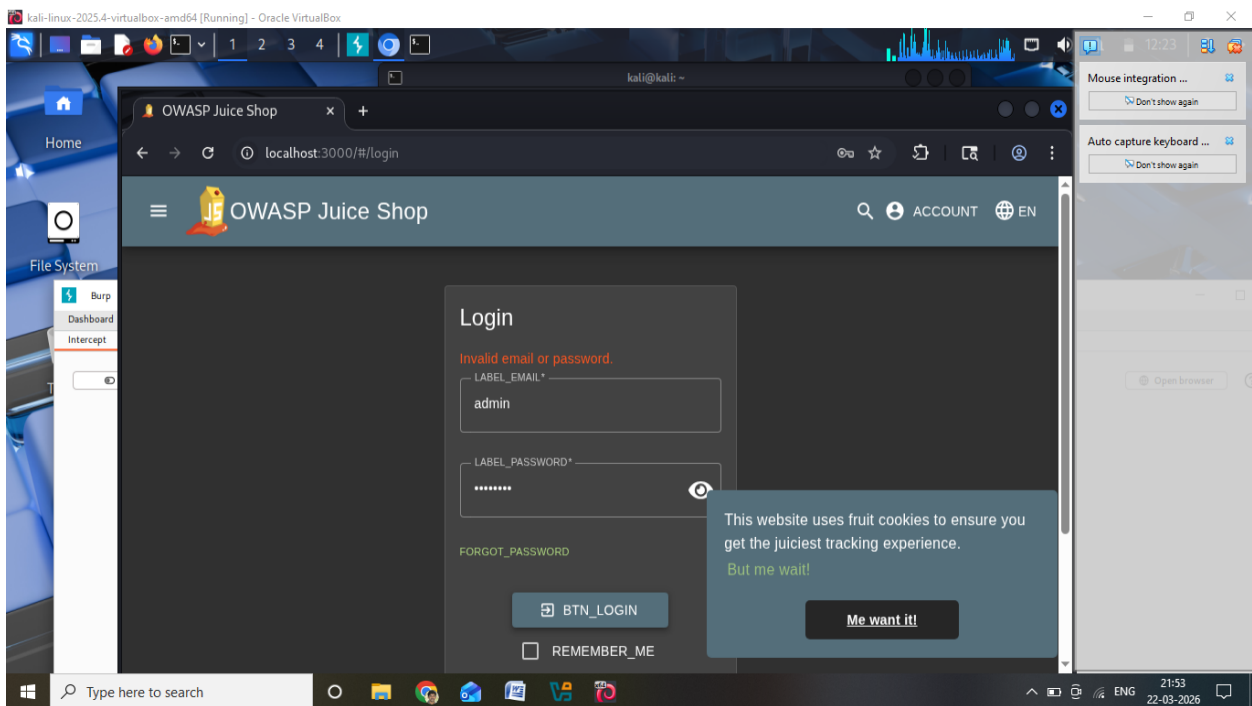
STEP 4: Enter Dummy Login Details

Enter any random values:

Email: admin

Password: password

Click **Login**



STEP 5: Capture Request in Burp

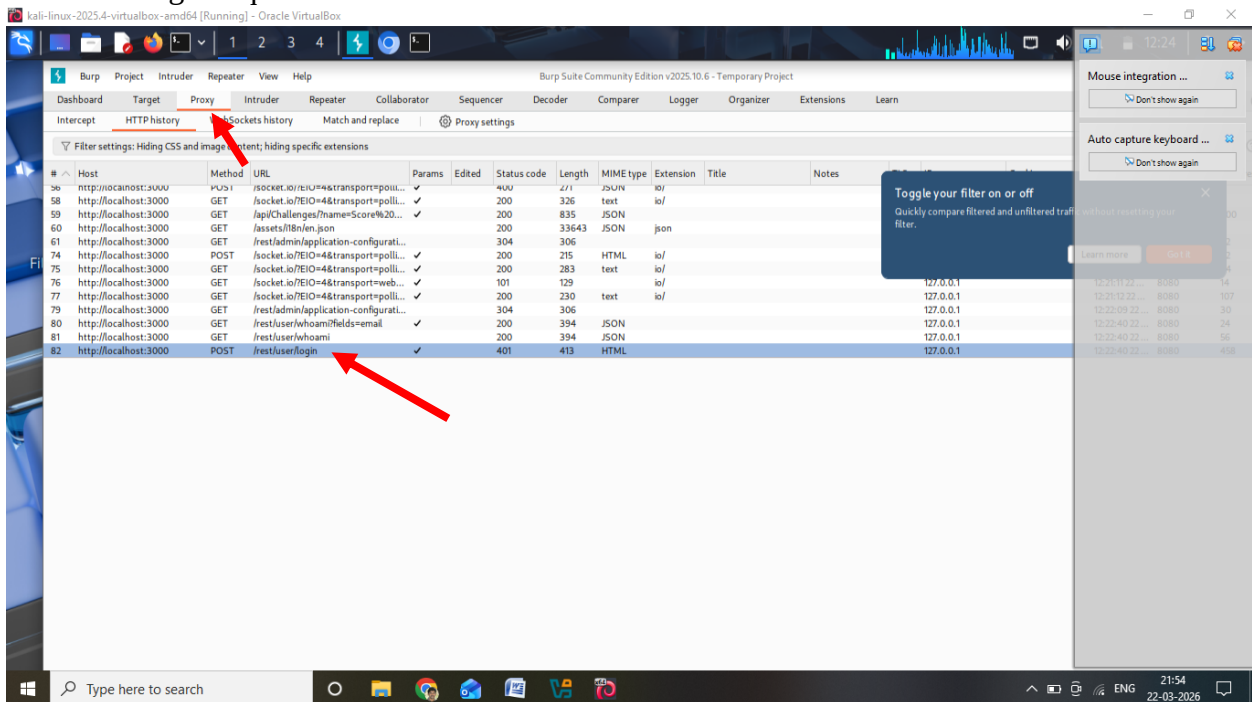
Now go to Burp:

Click **HTTP History**

Look for:

`/rest/user/login`

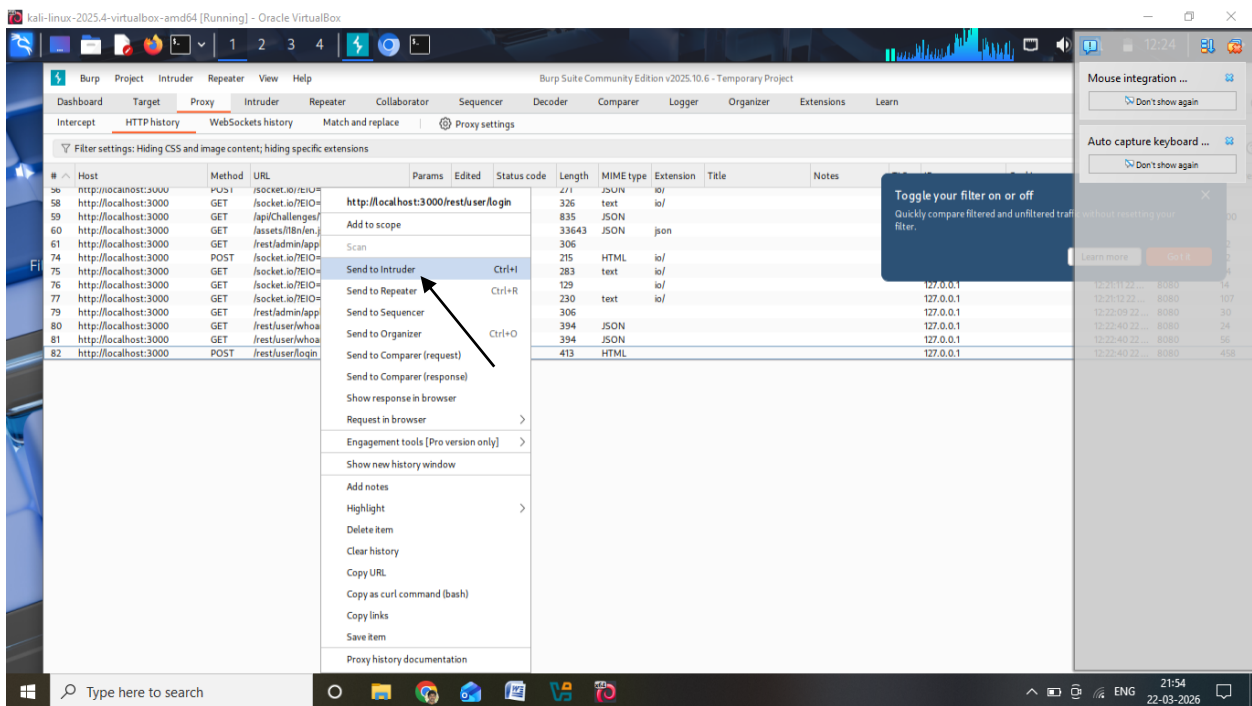
This is the login request



STEP 6: Send Request to Intruder

- Right-click on `/rest/user/login`
- Click:

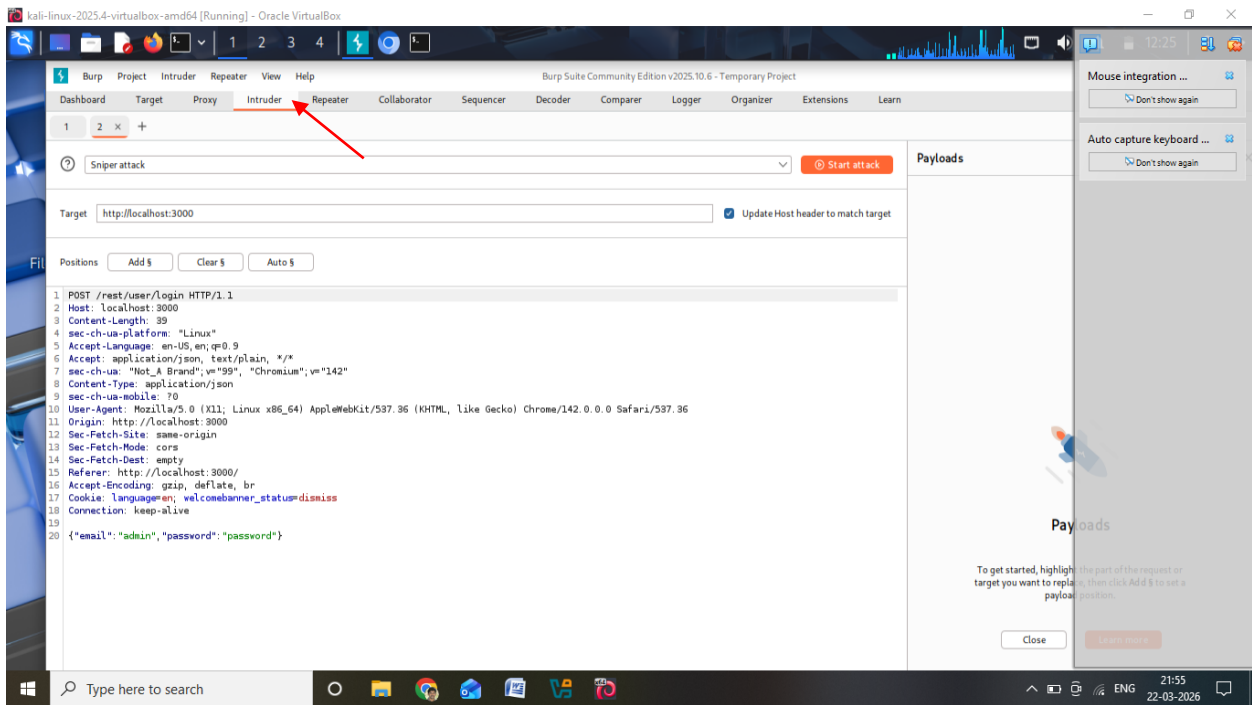
Send to Intruder



STEP 7: Configure Intruder Attack

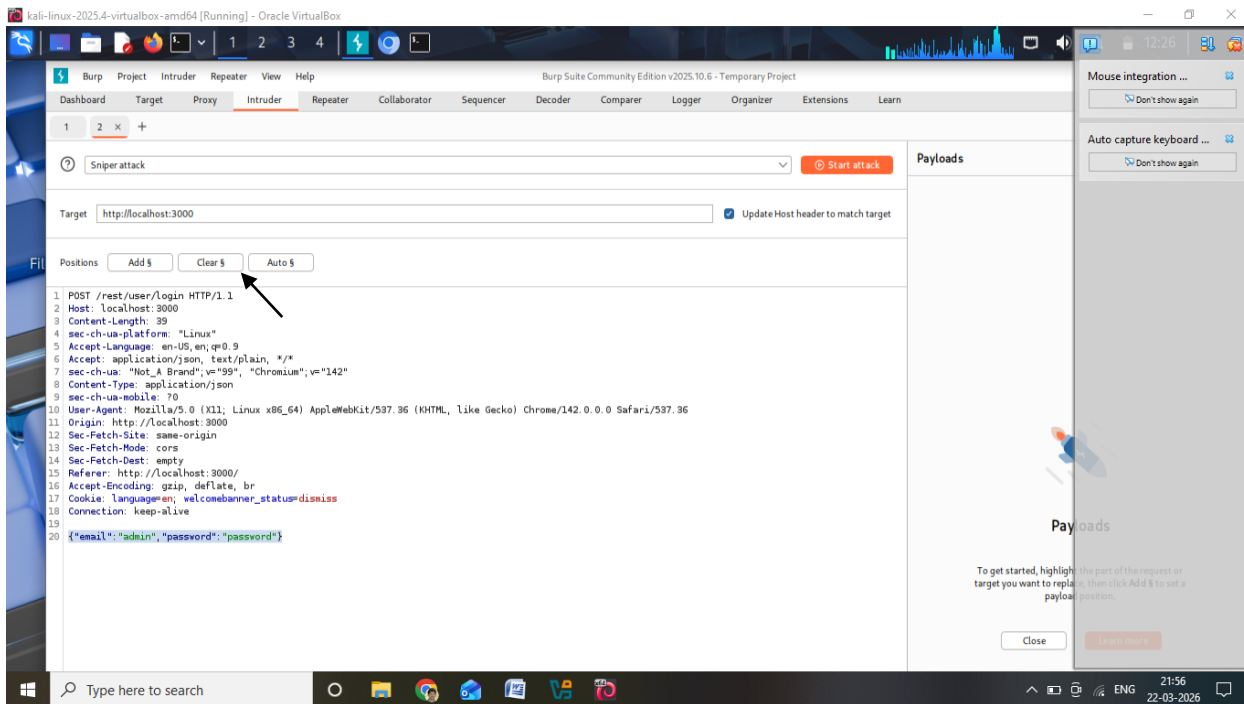
Go to:

Intruder tab



1. Positions Tab

- Click **Clear \$**
- Select email value:



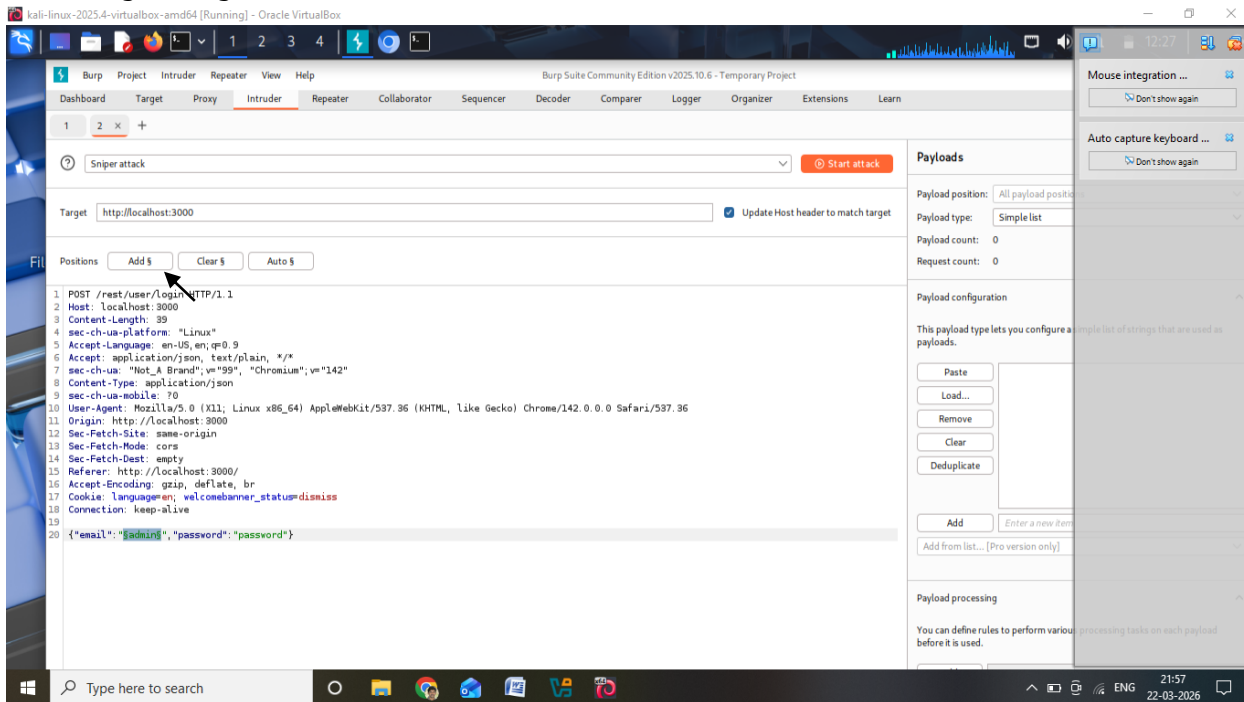
Example:

"email": "admin"

- Click Add \$

Now it becomes:

"email": "\$admin\$"



STEP 8: Add SQL Payloads

Go to:

Payloads tab

Open the website: <https://github.com/Ninja-Yubraj/SQL-Injection-Payloads-List>

copy and paste from: **Generic SQL Injection Payloads** Section

After unchecking URL encoder

Now paste SQL injection payloads.

Example Payload List:

' OR 1=1 --

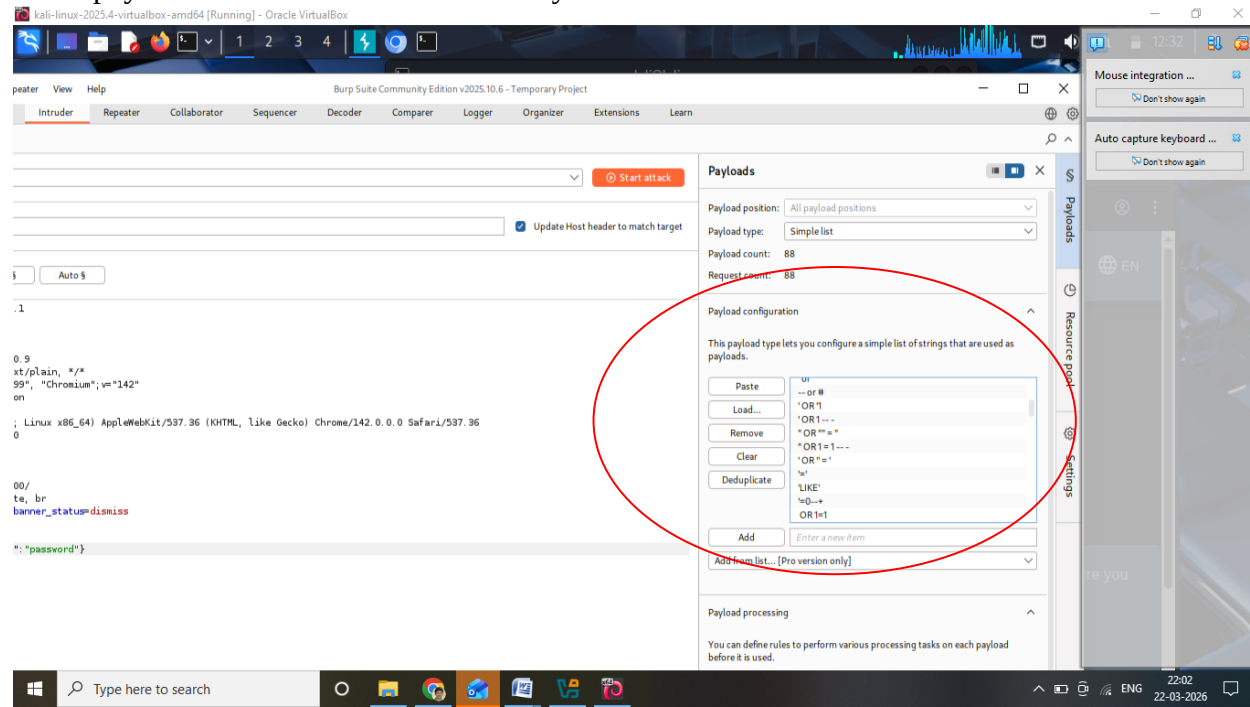
' OR '1'='1

admin' --

' OR 1=1#

' OR '='

These payloads will be tested automatically

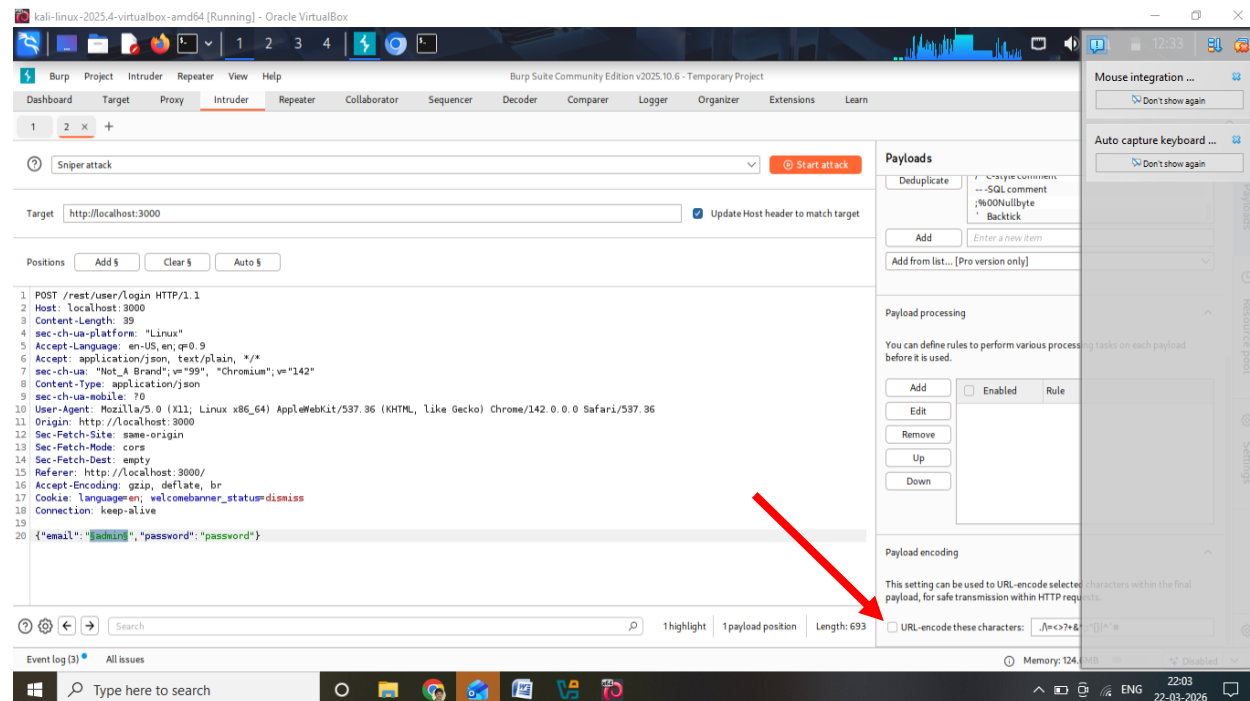


STEP 9: Disable URL Encoding

Very important:

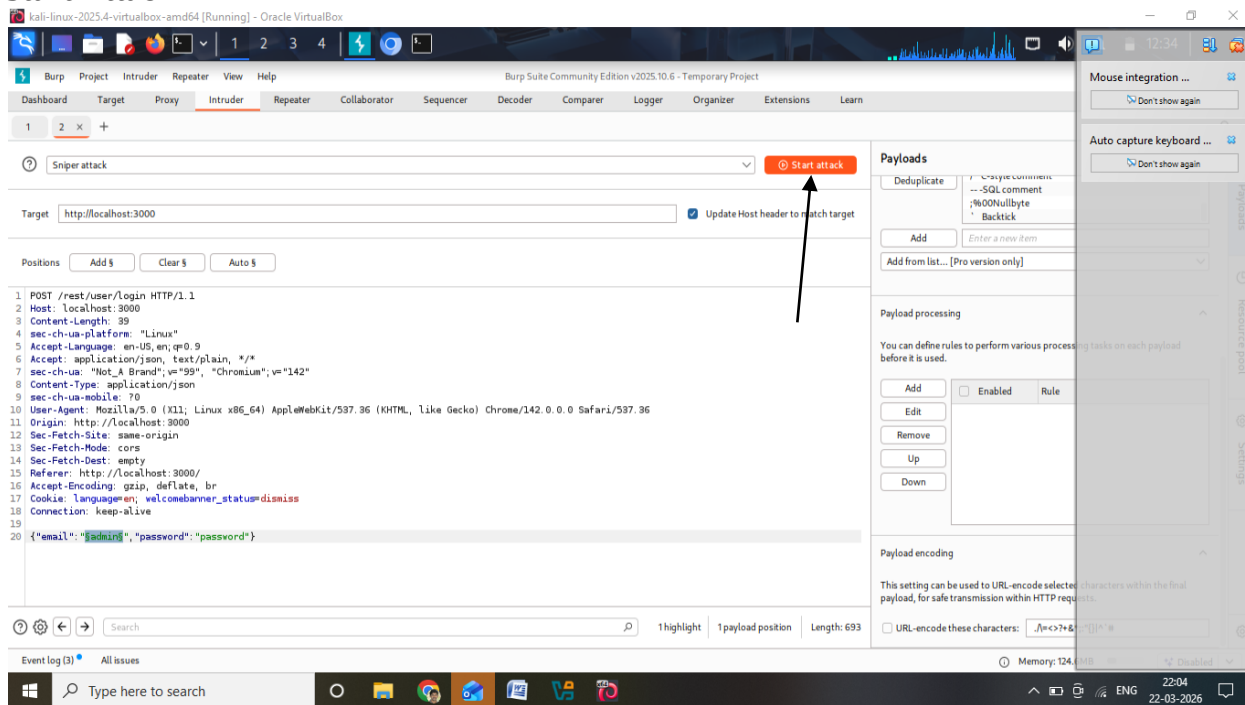
- Uncheck:

URL Encode these characters



STEP 10: Start Attack

Click: Start Attack



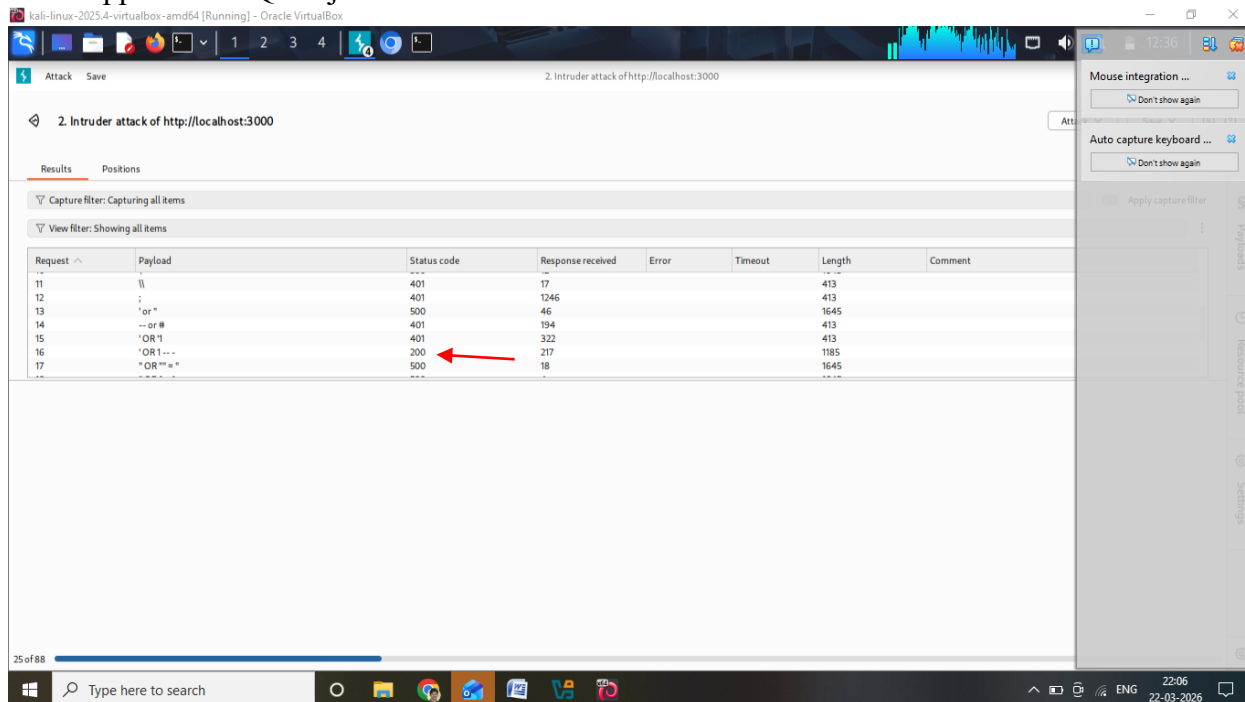
STEP 11: Analyze Results

You will see many responses.

Focus on:

- **Status Code = 200** ✓ (Success)
- Other codes = Failed

If 200 appears → SQL Injection worked



STEP 12: Extract Authentication Token

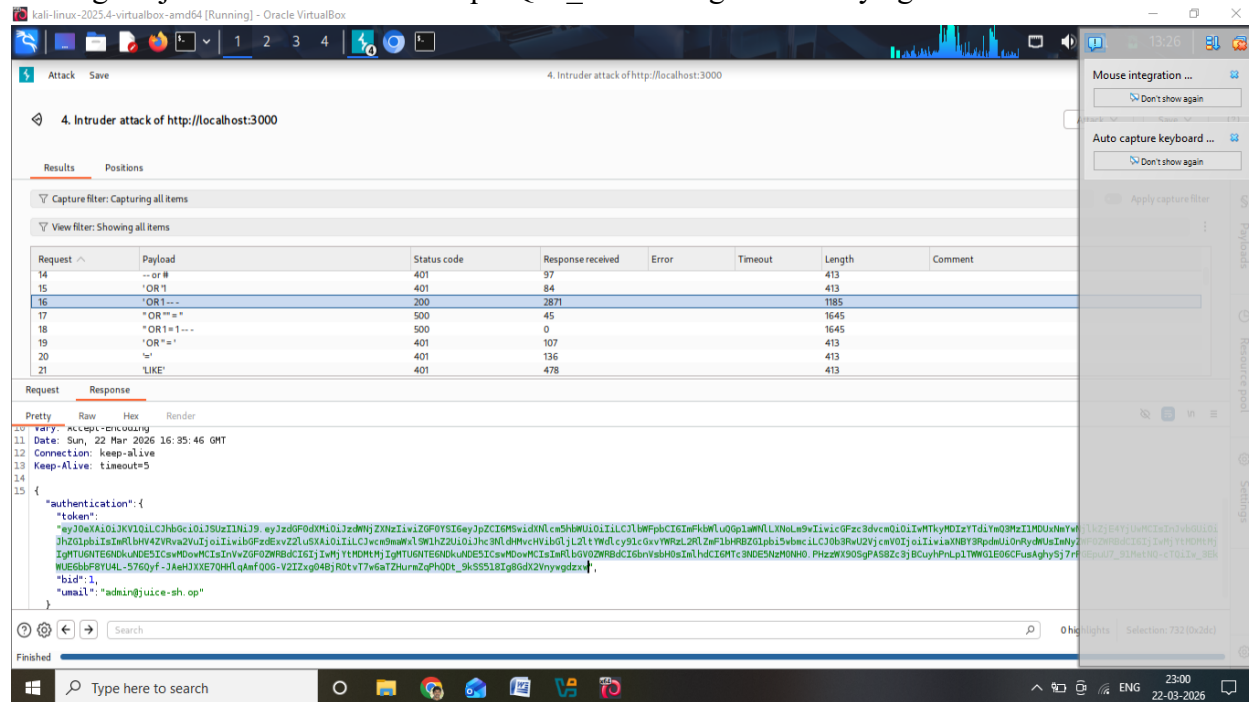
Click the 200 response

Go to:

Response tab

Copy it

“eyJ0eXAiOiJKV1QiLCJhbGciOiJSUzI1NiJ9.eyJzdGF0dXMiOiJzdWNjZXRzLiwiZGF0YSI6eyJpZCI6MSwiZXRlcml5bWUiOiIiLCJlbWVpbCI6ImFkbWluQGp1aWNlLXNoLm9wliwicGFzc3dvcml0eSI6MTkyMDIzYTdiYmQzMzI1MDUxNmYwNjlkZjE4YjUwMCIsInJvbGUOiJhZG1pbIsImRlbHV4ZVRva2VuIjoiliwiibGZzdExvZ2luSXAiOiIiLCJwcm9maWxlSW1hZ2UiOiJhc3NldHMvcHVibGljL2ltYWdlcy91cGxvYWZRL2RlZmF1bHRBZG1pbI5wbmciLCJ0b3RwU2VjcmV0IjoiliwiaXNBY3Rpdml0eSI6MTkyMDIzYTdiYmQzMzI1MDUxNmYwNjlkZjE4YjUwMCIsInJvbGUOiJhZG1pbIsImRlbGV0ZWRBdCI6bnVsbH0sImRlhdCI6MTc3NDE5NzM0NH0uPHZzWX9OSGpAS8Zc3jBCuyhPnLp1TWWG1E06CFusAghySj7rPGEpuU7_91MetNQ-cTQilw_3EkWUE6bbF8YU4L-576Qyf-JAeHJXXE7QHHLqAmfQOG-V2IZxg04BjROtvT7w6aTZHurMzQPhQDt_9kSS518Ig8GdX2Vnywgdzxw”



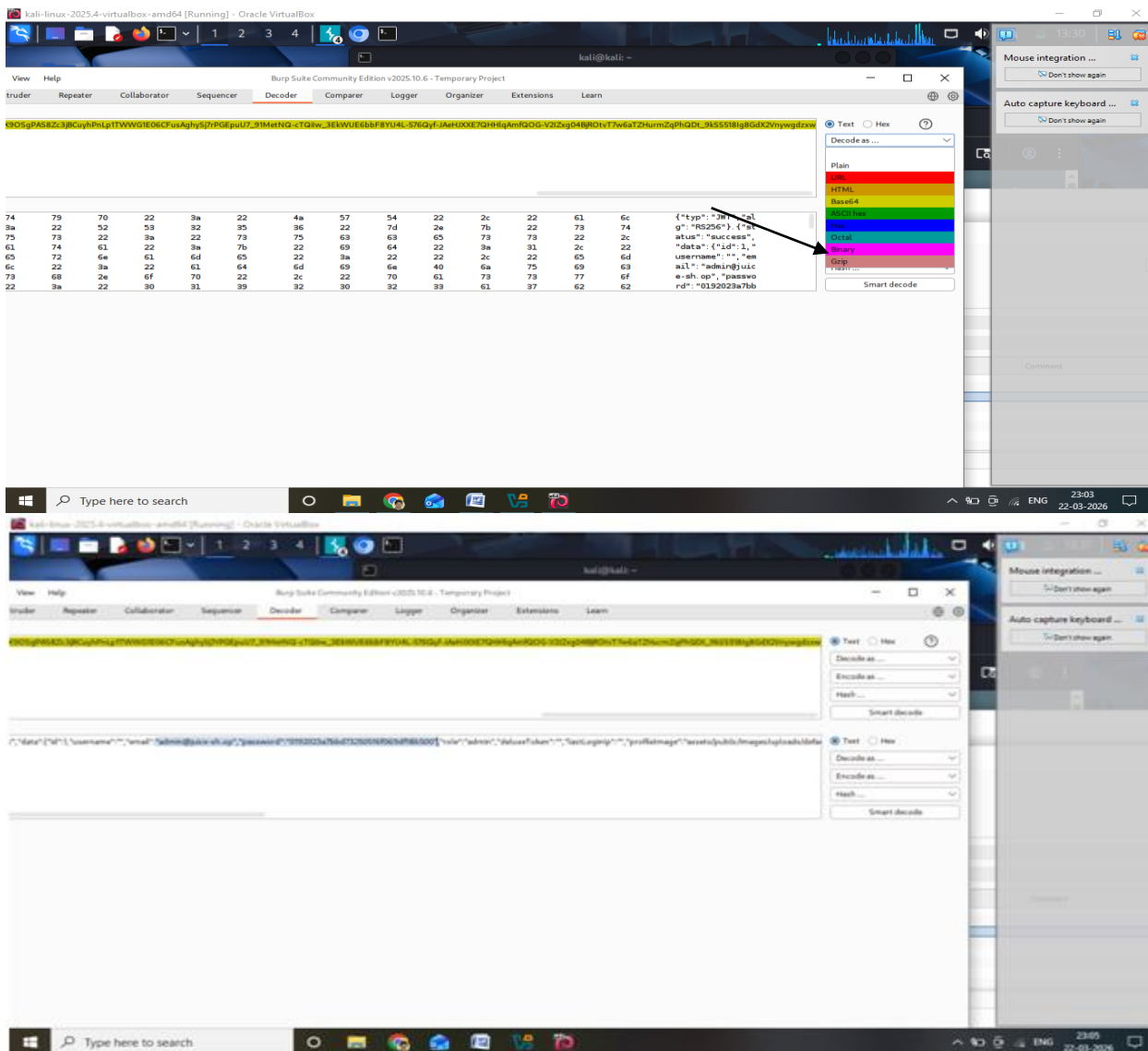
STEP 13: Decode Token

Go to:

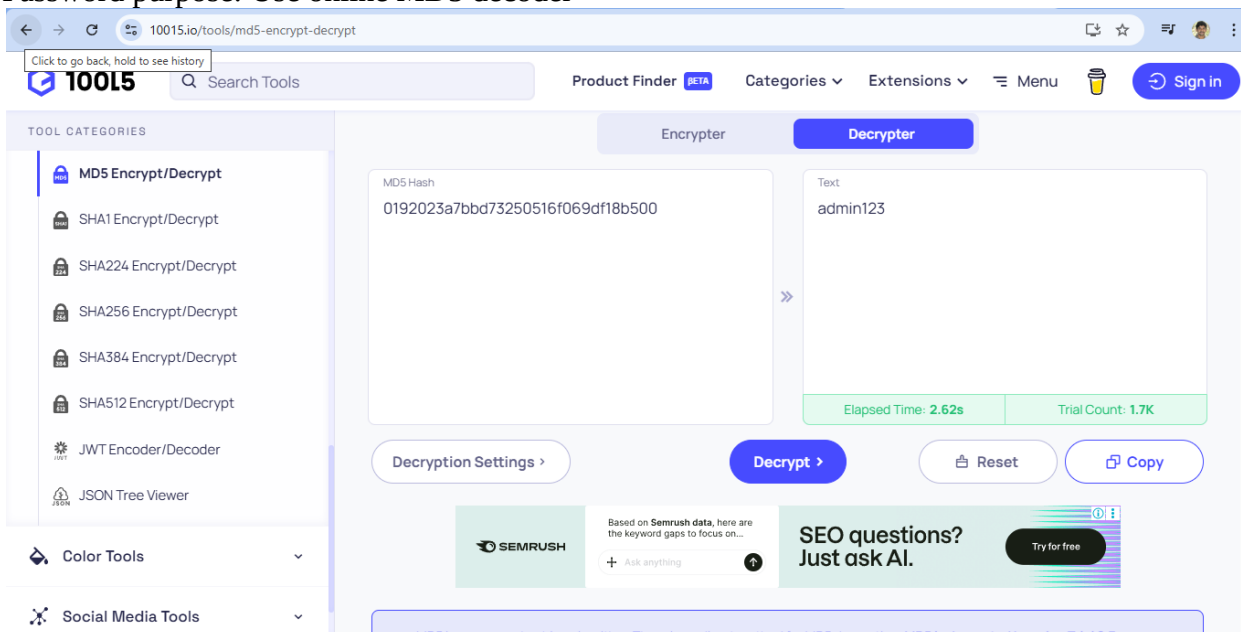
Decoder tab

1. Paste token
2. Select:

Decode as → Base64



Password purpose: Use online MD5 decoder



STEP 14: Get Credentials

After decoding, you will see:
email: admin@juice-sh.op

password: admin123

These are extracted credentials

STEP 15: Login Using Extracted Data

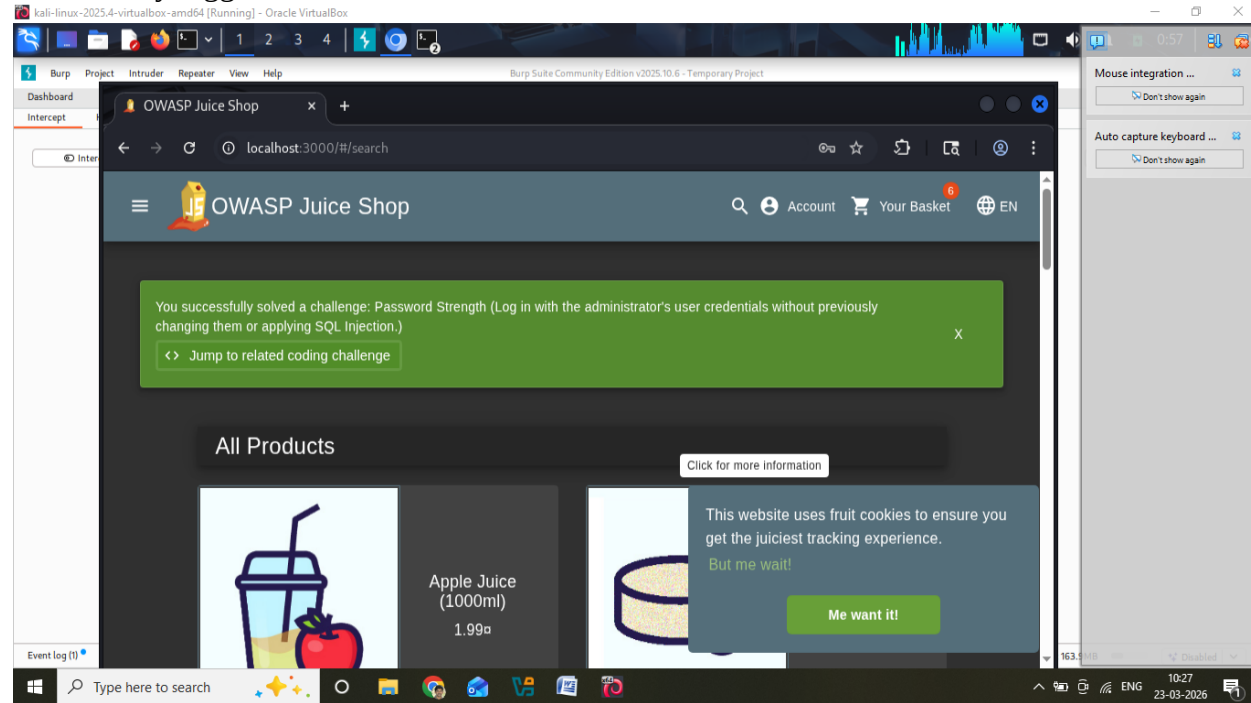
Go back to Juice Shop:

Enter:

- Email
- Password (decoded one)

Click Login

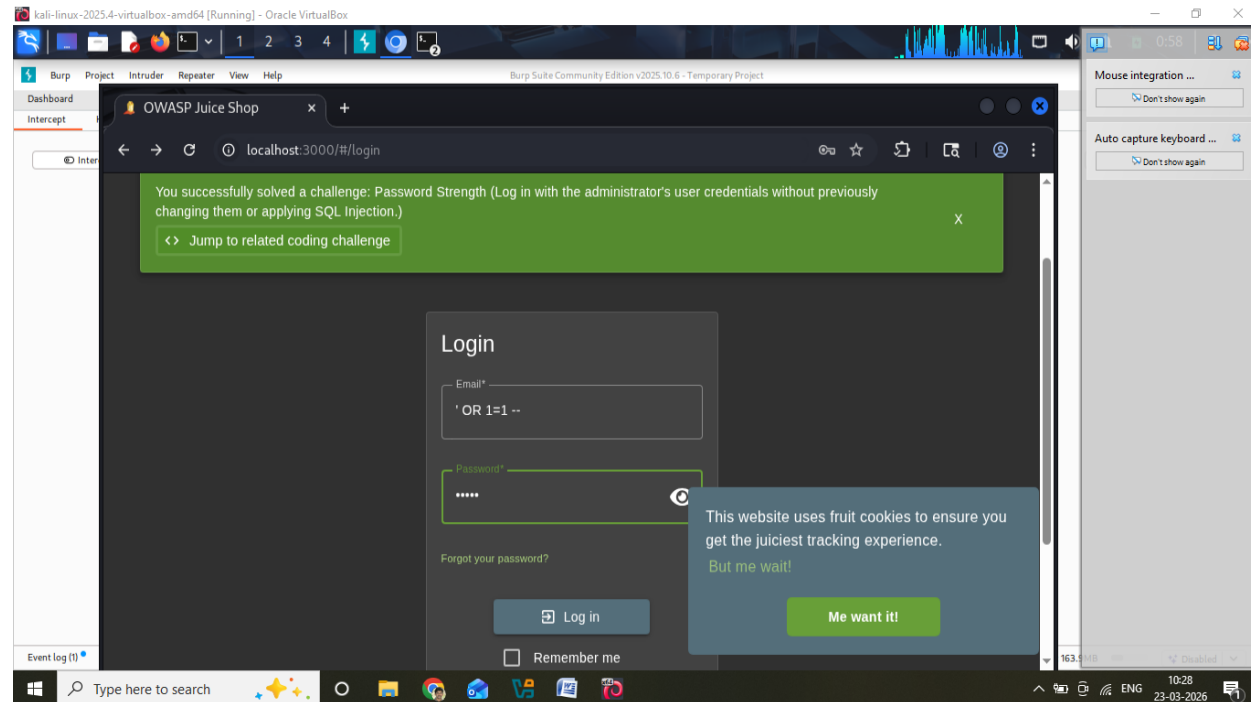
Successfully logged in



TYPES OF SQL INJECTION USED HERE

1. Authentication Bypass

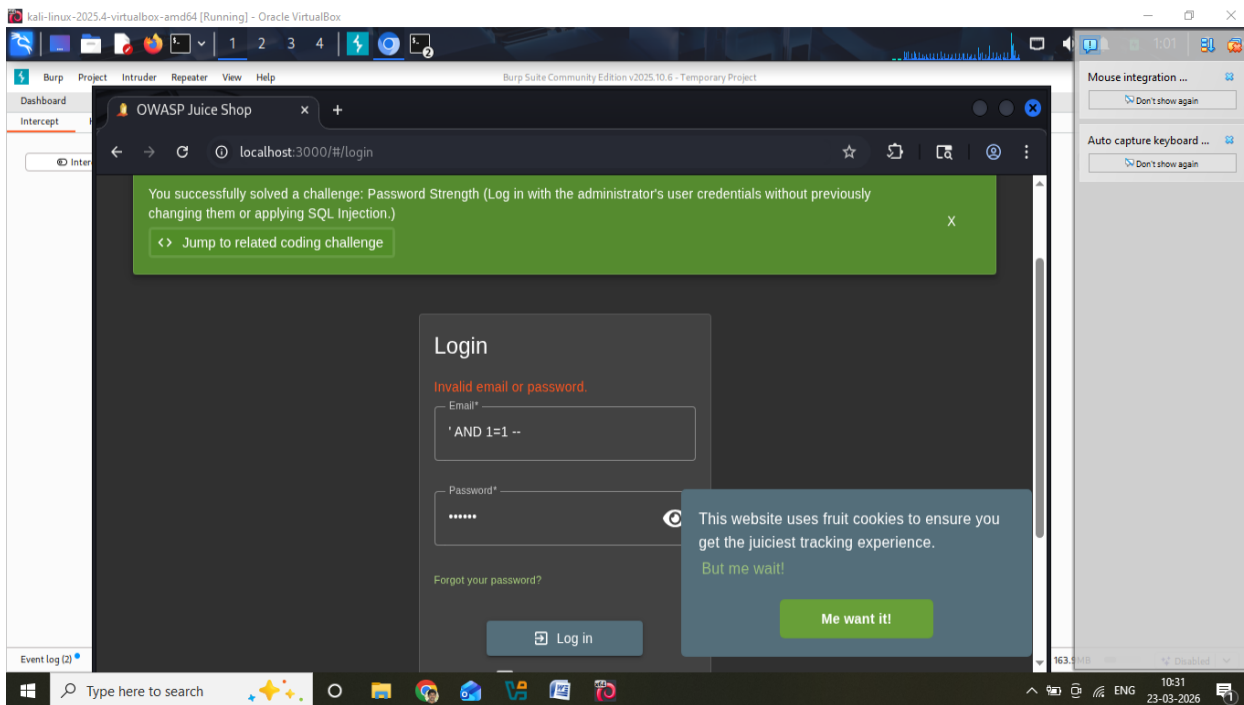
' OR 1=1 --



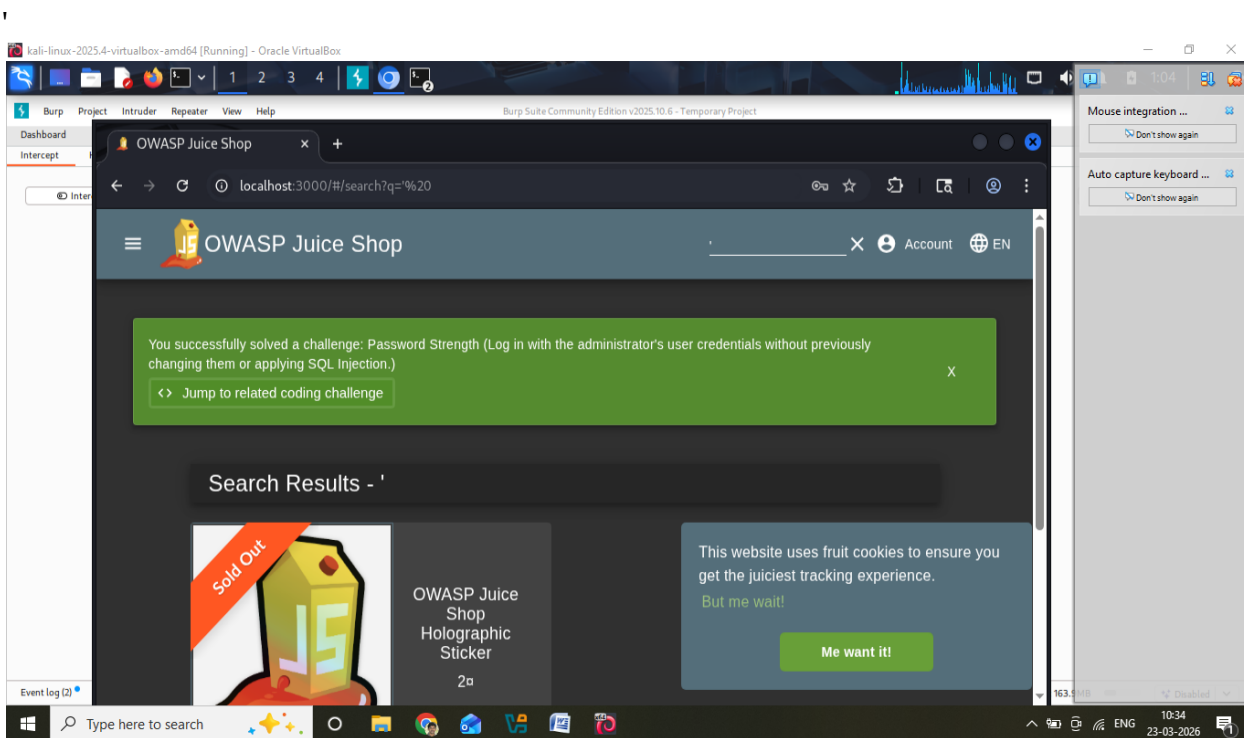
2. Boolean-Based (Blind)

' AND 1=1 --

' AND 1=2 --



3. Error-Based



4. Automated Injection (Intruder)

✓Testing multiple payloads automatically

RESULT

SQL Injection vulnerability successfully identified and exploited using Burp Suite.